CAHIER DES CHARGES

CandidBoost IA

Application web de recherche d’emploi et d’automatisation des candidatures

France • Multi-agents IA • Offres et candidatures spontanées

Plateforme	Application web uniquement dans cette phase. Aucune implémentation desktop, Electron ou installateur Windows.
Automatisation	Recherche, matching, rédaction, envoi via intégrations autorisées et suivi, avec limites et arrêt d’urgence.
Développement	Sprints progressifs dans le dépôt GitHub principal ; audit du code existant avant toute modification.
Budget	Minimiser les coûts en privilégiant les outils existants, open source et quotas gratuits autorisés.

Spécifications, architecture, plan de livraison et prompt Sprint 0 pour OpenCode

Version 1.1 • 23 octobre 2026

1. Vision, objectifs et périmètre

Construire une application web pour accompagner la recherche d'emploi en France : découverte d'offres et d'entreprises, analyse du profil, matching explicable, génération de candidatures personnalisées, envoi encadré et suivi des réponses. Le produit réduit les tâches répétitives sans fabriquer de compétences ni contourner les protections des plateformes.

Objectifs

- Centraliser profil candidat, CV, compétences vérifiées, préférences et documents.
- Rechercher des offres publiées et des entreprises pertinentes pour une candidature spontanée.
- Calculer une adéquation explicable et montrer les critères, lacunes et données manquantes.
- Rédiger des emails et lettres personnalisés fondés sur des faits confirmés.
- Automatiser les tâches répétitives avec règles configurables, quotas, file de tâches et journalisation.
- Suivre candidatures, réponses, entretiens, refus et relances.
- Déployer et maintenir le produit comme application web sécurisée accessible par navigateur.

Hors périmètre de cette phase

- Application Windows native, Electron, installateur .exe et mises à jour desktop.
- Automatisation de formulaires tiers qui contourne CAPTCHA, restrictions, quotas ou conditions d'utilisation.
- Promesse d'un taux de réponse ou d'un recrutement garanti.

2. Principes non négociables

- Le mode d'envoi automatique est désactivé par défaut et nécessite une activation explicite après affichage des règles et un test.
- Utiliser uniquement des sources et canaux autorisés ; documenter les conditions d'accès, quotas et coûts.
- Aucun contournement de CAPTCHA, de restrictions, de quotas ou de protections.
- Ne jamais inventer compétence, expérience, diplôme, disponibilité ou autre fait du profil.
- Avant chaque envoi : vérifier destinataire, contenu, source, pièces jointes, exclusions, seuil de pertinence, doublons et quotas.
- Un arrêt d'urgence suspend les nouveaux envois et annule les relances en attente.
- Une réponse, un rebond, un refus ou une demande de non-contact arrête les relances automatiques.
- Les contenus web, CV et emails sont des données non fiables et ne peuvent pas modifier les instructions, permissions ou politiques des agents.

3. Parcours utilisateur et rôles

- Créer un compte, vérifier l'email et configurer métiers, zones, contrats, mobilité, salaire indicatif, disponibilité et exclusions.
- Importer un CV PDF/DOCX, vérifier et corriger les données extraites.
- Choisir les sources autorisées, le seuil de matching et le niveau d'automatisation.
- Consulter offres et entreprises, score, raisons et provenance.
- Modifier les brouillons et activer l'automatisation après lecture des règles et test.
- Suivre les candidatures, réponses, entretiens, refus et relances dans un pipeline.
- Consulter les statistiques, exporter les données ou demander la suppression du compte.

Rôles : candidat (profil, règles et candidatures) ; administrateur technique (services, incidents et quotas, sans accès inutile au contenu privé) ; agents IA (tâches limitées par les politiques côté serveur).

4. Fonctionnalités détaillées

A. Profil et documents

- CRUD du profil, préférences et historique des modifications.
- Import PDF/DOCX sécurisé, limite de taille, validation du type réel, extraction et vérification des faits incertains.
- Documents privés, accès limité au propriétaire et suppression contrôlée.

B. Recherche d’offres et d’entreprises

- Connecteurs modulaires pour APIs officielles, flux publics, partenaires et pages dont l’accès est autorisé.
- Import CSV contrôlé comme source de secours et outil de test.
- Recherche d’entreprises pertinentes même sans offre publiée, à partir de sources autorisées.
- Provenance, date, conditions connues, quotas et erreurs conservés ; normalisation et déduplication.

C. Matching explicable

- Score configurable : compétences, expérience, localisation, contrat et préférences.
- Afficher raisons positives, écarts, données manquantes et provenance.
- Score déterministe et testable ; l’IA ne modifie pas arbitrairement les règles critiques.

D. Rédaction

- Générer email et lettre à partir des faits confirmés et de l’offre/entreprise ciblée.
- Édition, aperçu, versions, validation des pièces jointes et historique.
- Signaler les affirmations non étayées au lieu de les inventer.

E. Envoi et automatisation

- Un connecteur mail au départ via OAuth/API officielle ou SMTP autorisé.
- File de tâches persistée, idempotence, reprise limitée, délais, quotas et journal des événements.
- Règles : plafond quotidien, délai minimum, horaires, seuil de matching, domaines exclus et maximum de relances.
- Simulation avant envoi réel, puis test vers une adresse contrôlée par l’utilisateur.
- Formulaires tiers automatisés uniquement via API ou méthode officiellement autorisée.

F. Suivi et relances

- Statuts normalisés : à qualifier, brouillon, planifiée, envoyée, erreur, réponse, entretien, refus, clôturée.
- Détection des réponses par messagerie autorisée ou saisie manuelle.
- Cas ambigus soumis à vérification ; annuler les relances après réponse, rebond, refus, opposition ou arrêt d’urgence.

G. Statistiques et paramètres

- Volumes, taux de réponse, entretiens, refus, délais par source/campagne.
- Afficher périodes, dénominateurs et données manquantes ; pas de causalité inférée à tort.
- Export CSV/JSON, connexions, budget IA et suppression des données.

5. Architecture technique et multi-agents

Le Sprint 0 doit auditer le dépôt et confirmer la stack. Réutiliser l’existant plutôt que réécrire sans justification.

- Frontend : framework web existant, responsive et accessible.
- Backend : API versionnée, validation stricte et autorisation par utilisateur ; réutiliser le backend existant s’il est maintenable.
- Base : PostgreSQL recommandé en production avec migrations reproductibles.
- File de tâches : démarrer simple, persistante et idempotente ; ajouter une infrastructure dédiée si le volume l’exige.
- Documents : stockage privé, chiffrement, rétention et aucun lien public permanent.
- IA : interface fournisseur abstraite, prompts versionnés, sorties structurées, limites de coût, cache et fallback sans IA.
- Observabilité : logs structurés sans CV ni jetons, métriques, alertes sur erreurs, coûts et tâches bloquées.
- Déploiement : local/staging/production, secrets côté serveur, CI, sauvegardes, health checks et rollback.

Agents

- Orchestrateur — Planifie les tâches, vérifie les permissions et stoppe le flux en cas de règle non satisfaite.
- Profil — Normalise les données du CV et sépare faits confirmés, incertains et absents.

- Sourcing — Interroge les connecteurs autorisés ; renvoie résultats sourcés, datés et dédupliqués.
- Matching — Calcule un score explicable et en résume les raisons.
- Rédaction — Prépare des brouillons fondés sur les faits confirmés.
- Contrôle qualité/conformité — Vérifie exactitude, doublons, exclusions, destinataire, contenu et règles.
- Envoi — Exécute uniquement les tâches autorisées par les politiques serveur.
- Suivi — Traite les réponses et arrête les relances lorsque nécessaire.
- Analyste — Produit des statistiques descriptives sans garantir de résultat.

Flux et modèle de données

Flux : source autorisée → collecte/provenance → normalisation/déduplication → matching → brouillon → contrôle → règles serveur → simulation/planification → envoi → journal → suivi.

Entités minimales : User, CandidateProfile, CVDocument, Skill, Experience, Preference, ConsentRecord, SourceConnector, Company, Contact, JobOffer, MatchEvaluation, ApplicationDraft, Application, SendingPolicy, Task, MessageEvent, Reply, Interview, SuppressionEntry, AuditLog, ProviderCredentialRef, UsageMeter. Cloisonner par propriétaire, avec contraintes d'unicité, dates, rétention et audit.

6. Sécurité, confidentialité et conformité

- RGPD : documenter finalités, base légale, information, minimisation, droits, conservation, sous-traitants et procédure de violation ; faire valider juridiquement les choix.
- Une adresse professionnelle publique n'est pas une autorisation illimitée : vérifier les règles selon canal, destinataire, finalité et opposition.
- Chiffrer les jetons OAuth au repos ; ne jamais exposer les secrets dans frontend ou logs ; rotation et révocation.
- Sessions sécurisées, vérification email, protection CSRF selon architecture, limitation de débit et MFA si approprié.
- Tests d'isolation des comptes, anti-IDOR, validation stricte des entrées et fichiers.
- Défenses contre l'injection de prompt ; minimiser les données transmises au modèle.
- Quotas, backoff, circuit breaker, idempotence, exclusions, arrêt d'urgence et arrêt sur rebond/réponse.
- Afficher règles actives, source et contenu avant activation ; journaliser l'activation automatique.
- Export et suppression selon une politique de conservation définie.

7. Plan des sprints OpenCode

Règle générale : dépôt GitHub principal, branche dédiée par sprint, audit préalable, modifications incrémentales, conservation des fonctionnalités existantes, tests et compte rendu des fichiers touchés. Aucun secret ni donnée personnelle réelle dans Git.

Sprint 0 — Audit et plan d'intégration

- Inspecter arborescence, stack, dépendances, scripts, tests, authentification, base, API, interface web, déploiement et intégrations.
- Identifier composants réutilisables, dettes techniques, risques et inconnues.
- Documenter architecture, variables d'environnement, commandes et tests.
- Créer/mettre à jour docs/architecture.md, docs/roadmap.md, docs/risks.md et docs/decisions/ADR-*.md.
- Ne pas refondre ni implémenter les sprints suivants.

Critère de sortie : Sortie : audit, plan de livraison, risques priorisés et commandes reproductibles.

Sprint 1 — Socle web et navigation

- Adapter les pages Tableau de bord, Profil, Offres, Entreprises, Candidatures, Automatisations, Statistiques, Paramètres.
- Composants cohérents, responsive, accessibles, états vides/chargement/erreur.
- Données de démonstration identifiées, jamais mélangées aux données réelles.

Critère de sortie : Sortie : interface web navigable et tests UI.

Sprint 2 — Profil et documents

- CRUD du profil et préférences.

- Import PDF/DOCX sécurisé avec extraction et écran de vérification.
- Conserver provenance et statut confirmé/non confirmé.

Critère de sortie : Sortie : profil fonctionnel et tests d’accès/fichiers.

Sprint 3 — Base, API et autorisations

- Migrations, modèles, validation, pagination, filtres et API versionnée.
- Isolation par utilisateur, audit, export et suppression.
- Documenter endpoints et autorisations.

Critère de sortie : Sortie : API testée, migrations reproductibles et tests anti-IDOR.

Sprint 4 — Connecteurs de recherche

- Définir SourceConnector avec provenance, date, quotas, conditions d’utilisation et erreurs.
- Implémenter import CSV et au moins une source API/flux autorisée et documentée.
- Ne pas scraper sans vérifier les conditions ; aucun contournement de contrôle.
- Normaliser et dédupliquer offres/entreprises.

Critère de sortie : Sortie : source fonctionnelle, connecteur simulé et fiche source.

Sprint 5 — Matching explicable

- Score reproductible selon compétences, expérience, localisation, contrat et préférences.
- Afficher raisons, écarts et informations manquantes.
- Tests des cas limites ; pas d’hallucination dans le score.

Critère de sortie : Sortie : matching explicable couvert par tests.

Sprint 6 — Infrastructure et agents IA

- Interface LLMProvider, prompts versionnés, validation de sortie, timeouts, retries limités et suivi des coûts.
- Implémenter Orchestrateur, Profil, Sourcing, Matching, Rédaction et Contrôle avec contrats typés.
- Tests sur données fictives et fallback sans IA.

Critère de sortie : Sortie : agents traçables, observables et limités par les politiques serveur.

Sprint 7 — Rédaction

- Générer email et lettre fondés sur faits confirmés et cible.
- Édition, aperçu, versions et validation des pièces jointes.
- Signaler toute affirmation non étayée.

Critère de sortie : Sortie : brouillons éditables et tests de non-invention.

Sprint 8 — Pipeline et historique

- Statuts et historique de candidature.
- Déduplication par candidat, entreprise, offre, canal et période.
- Saisie manuelle des réponses, entretiens et refus.

Critère de sortie : Sortie : suivi complet avant envoi automatique.

Sprint 9 — Intégration messagerie

- Un seul fournisseur via OAuth/API officielle ou SMTP autorisé.
- Permissions minimales, stockage sécurisé et révocation des jetons.
- File persistée, idempotence, quotas, reprises limitées et journal.
- Simulation puis test vers une adresse contrôlée par l’utilisateur.

Critère de sortie : Sortie : envoi testable sans doublon lors des reprises.

Sprint 10 — Automatisation sécurisée

- Mode désactivé par défaut ; activation explicite après règles visibles et test.
- Plafond quotidien, délai, horaires, seuil, domaines exclus et limite de relances.
- Contrôle serveur de chaque envoi : destinataire, contenu, source, pièces jointes, exclusions, quotas, doublons.
- Arrêt d'urgence et suspension sur erreurs, rebonds ou non-contact.
- Pas de contournement de CAPTCHA, restrictions, quotas ou conditions.

Critère de sortie : Sortie : automatisation limitée et tous les coupe-circuits testés.

Sprint 11 — Réponses et relances

- Détection autorisée des réponses ou saisie manuelle.
- Classification avec niveau de confiance ; cas ambigus à vérifier.
- Annuler relances après réponse, rebond, refus, opposition ou arrêt.
- Limite de fréquence et modèles éditables.

Critère de sortie : Sortie : suivi fiable et annulation vérifiée.

Sprint 12 — Statistiques, export, suppression

- Calculer volumes, réponses, entretiens, refus, délais et résultats par source.
- Afficher périodes et dénominateurs.
- Export CSV/JSON, fermeture de compte et suppression selon politique.

Critère de sortie : Sortie : calculs testés, export et suppression documentés.

Sprint 13 — Sécurité et robustesse

- Renforcer validation, rate limiting, CSP, cookies, CSRF/XSS selon stack.
- Tester isolation, IDOR, injection de prompt, fichiers hostiles, secrets et permissions OAuth.
- Documenter données, rétention, sous-traitants, incident et restauration.
- Tester panne fournisseur, quotas, jetons révoqués et reprises.

Critère de sortie : Sortie : rapport sécurité, tests automatisés et plan de correction.

Sprint 14 — Déploiement web et CI/CD

- Environnements local/staging/production, configuration et migrations contrôlées.
- CI : lint, types, tests unitaires/intégration/e2e, build et dépendances.
- HTTPS, secrets, sauvegardes, health checks, logs sans données personnelles et alertes.
- Documentation du déploiement, restauration, rollback et incident.

Critère de sortie : Sortie : déploiement reproductible et runbooks.

Sprint 15 — Bêta et lancement

- Recette bout en bout sur données fictives puis test réel à faible volume.
- Observation/simulation, test d'envoi, puis quota réduit après validation explicite.
- Vérifier coûts, conditions sources, sécurité, suppression et critères d'acceptation.
- Guide utilisateur, FAQ, changelog, limites et support.

Critère de sortie : Sortie : bêta validée et plan de lancement.

8. Tests et critères d'acceptation

- Unitaires : matching, normalisation, doublons, quotas, idempotence et relances.
- Intégration : base, migrations, sources, messagerie, file de tâches et réponses.
- End-to-end : profil → recherche → matching → brouillon → contrôle → simulation → envoi test → suivi.
- Sécurité : isolation utilisateurs, secrets absents des logs, documents privés, injection et fichiers hostiles.
- Fiabilité : tâche rejouée, fournisseur indisponible, timeout, quota atteint, jeton révoqué, redémarrage et restauration.

- Accessibilité : navigation clavier, contrastes, responsive et principaux navigateurs.

Critères globaux

- Le candidat peut corriger les données extraites du CV.
- Chaque offre/entreprise montre source, date et raisons du matching.
- Une candidature ne peut pas être envoyée deux fois accidentellement.
- Automatisation désactivée par défaut, activée explicitement.
- Quotas, exclusions, arrêt d'urgence et suppression ont des tests.
- Le produit fonctionne en mode dégradé si IA/source est indisponible.
- CI et procédures de déploiement/restauration sont reproductibles.

9. Budget minimal

- Réutiliser les services existants s'ils sont sûrs et adaptés.
- Privilégier APIs autorisées, open source et import CSV ; vérifier les limites des plans gratuits.
- Abstraire le fournisseur IA ; comparer modèle économique et option locale si maintenable.
- Limiter tokens, mettre en cache les résultats reproductibles et réserver l'IA aux tâches utiles.
- Commencer avec un seul fournisseur mail et un faible volume.
- Mesurer le coût par candidature et prévoir des alertes de budget.

Avant la production, OpenCode doit estimer les coûts mensuels. Ne pas supposer qu'un plan gratuit restera gratuit.

10. Documentation attendue

- README.md : installation locale, variables, scripts, tests et démarrage.
- docs/architecture.md et docs/decisions/ : architecture et décisions.
- docs/security.md : menaces, secrets, permissions, sauvegardes et incidents.
- docs/privacy-rgpd.md : données, finalités, rétention, droits et sous-traitants, à faire valider.
- docs/connectors.md : sources, conditions, quotas, coûts et révocation.
- docs/automation.md : règles, plafonds, simulation et arrêt d'urgence.
- docs/deployment.md : staging/production, secrets, migrations, sauvegardes et rollback.
- docs/runbooks/ : incidents IA, messagerie, base, tâches et sécurité.
- CHANGELOG.md : changements par version.

11. Prompt maître OpenCode — Sprint 0 uniquement

```
Tu travailles dans le dépôt GitHub principal de mon projet CandidBoost IA. Je veux construire une APPLICATION WEB UNIQUEMENT in

PÉRIMÈTRE
- Application web accessible depuis un navigateur.
- Aucun Windows natif, Electron, installateur .exe ou fonctionnalité desktop dans cette phase.
- Fonctionnalités futures : profil/CV, recherche autorisée d'offres et d'entreprises, matching explicable, rédaction personnali
- Mode automatique désactivé par défaut ; activation explicite, quotas, exclusions, idempotence, journalisation et arrêt d'urge
- Aucun contournement de CAPTCHA, restrictions, quotas ou conditions d'utilisation.
- Ne jamais inventer les compétences, expériences, diplômes ou disponibilités du candidat.
- Les agents IA ne peuvent pas modifier les permissions ni les règles de sécurité côté serveur.

RÈGLES
1. Commence UNIQUEMENT par le Sprint 0 : audit et plan d'intégration.
2. Inspecte arborescence, stack, dépendances, scripts, tests, authentification, base, API, interface web, déploiement et intégr
3. Réutilise l'existant ; ne réécris pas sans justification démontrable.
4. N'implémente aucune fonctionnalité produit des sprints suivants.
5. Ne révèle ni ne committe secrets, jetons, mots de passe ou données personnelles réelles.
6. Identifie les composants à conserver, lacunes, risques, dépendances, inconnues et coûts potentiels.
7. Produis ou mets à jour si pertinent : docs/architecture.md, docs/roadmap.md, docs/risks.md, docs/decisions/ADR-*.md et une l
8. Vérifie les commandes existantes de lint, tests et build. Exécute celles qui sont sûres et disponibles et rapporte les résul
9. À la fin, fournis : architecture actuelle, stack, fonctionnalités existantes, fichiers examinés/modifiés, commandes/résultat
10. Ne commence pas le Sprint 1 avant ma demande explicite.

Commence maintenant le diagnostic du dépôt. Ne développe pas encore l'application et ne modifie aucune fonctionnalité existante
```

12. Ordre de lancement recommandé

Démarrer par les Sprints 0 à 8 pour valider le socle, la recherche, le matching, la rédaction et le suivi. Ajouter ensuite la messagerie et l’automatisation après vérification des règles des sources et canaux. Terminer par statistiques, sécurité, déploiement et recette. L’objectif est une automatisation ciblée et traçable, pas des envois massifs non pertinents.